05. CYBERSECURITY DOMAIN & INCIDENT RESPONSE

Threat Management, MITRE ATT&CK, Vulnerability Lifecycles & SOC Operations

Target Role: Cybersecurity Intern – Evernorth Health Services (The Cigna Group)
Candidate: Anshika Keshari — **Target Location:** Hyderabad Innovation Hub

Module Overview & JD Cross-Reference

The Evernorth Cybersecurity Internship JD explicitly requires: *"Support threat management activities, including threat analysis, threat intelligence research, cyber risk assessments, and vulnerability management initiatives. Contribute to security metrics, dashboards, and reporting."* This document gives you the complete technical grounding, vocabulary, real-world analogies, and battle-tested incident response playbooks needed to excel in these specific domains.

1. The Healthcare Threat Landscape & Evernorth Context

Why Healthcare Cybersecurity is Unique (High-Value PHI + Life Safety)

- **High Black-Market Value of PHI:** A stolen credit card sells for $1–$5 on the dark web because it can be frozen in seconds. A complete Protected Health Information (PHI) record (SSN, medical history, insurance ID, date of birth) sells for $50–$250 because medical identity theft cannot be easily "cancelled" or re-issued.
- **Zero-Downtime Availability Constraint:** In typical corporate IT, isolating a server stops emails. In Evernorth and hospital networks, severing network connections can delay insulin shipments, freeze real-time chemotherapy approvals, or disrupt telemetry in patient care.
- **Regulatory Stakes (HIPAA & HITECH):** The Health Insurance Portability and Accountability Act mandates three security safeguard pillars: *Administrative* (policies, access management), *Physical* (workstation and data center access), and *Technical* (AES-256 encryption in transit and at rest, audit logging, multi-factor authentication). Non-compliance results in Tier 4 penalties exceeding $1.9M per year plus mandatory public breach notifications.

The Change Healthcare / ALPHV Incident (The Defining 2024 Event)

What Happened: In February 2024, Change Healthcare (processing 15 billion healthcare claims annually) was breached by the ALPHV/BlackCat ransomware syndicate via a single Citrix remote-access portal that lacked Multi-Factor Authentication (MFA). **The Fallout:** Prescription claims across the United States froze for weeks, causing pharmacy cash-flow crises. **Evernorth's Response:** Evernorth and Express Scripts had to rapidly verify pharmacy routing redundancy, isolate untrusted EDI clearinghouse pipelines, and conduct emergency third-party risk assessments across all interconnected APIs.

2. Cyber Threat Intelligence (CTI) & Frameworks

First Principles: What is CTI?

Everyday Analogy: Think of an airport security watchlist and meteorological weather radar. Rather than waiting for a storm or an unauthorized intruder to hit the terminal, meteorologists track atmospheric pressure hours ahead, and border agencies share biometric watchlists across nations. Threat Intelligence is the radar and watchlist for corporate cyberspace.

The Three Tiers of Threat Intelligence

David Bianco's Pyramid of Pain (Crucial Interview Concept)

The Pyramid of Pain measures the difficulty an adversary faces when you block a specific indicator type:

CTI Tier	Audience	Content / Focus	Example at Evernorth
Strategic	CISO, Board of Directors, VP of Security	High-level business risk, geopolitical cyber threats, financial loss projections.	Briefing leadership on Russian state-sponsored attacks targeting US pharmacy infrastructure.
Operational	SOC Managers, Incident Handlers	Adversary intent, campaigns, attack timelines, actor profiling.	Tracking the BlackCat ransomware gang's active targeting of healthcare EDI clearinghouses.
Tactical / Technical	SOC Level 1/2 Analysts, SIEM Engineers	Indicators of Compromise (IoCs): IPs, domain hashes, Yara rules, CVE exploit signatures.	Ingesting STIX/TAXII feeds of malicious C2 IPs into Evernorth firewalls and Splunk SIEM.

1. **Hash Values (Trivial):** SHA-256/MD5 hashes. Trivial for attackers to change by altering 1 byte in the binary.
2. **IP Addresses (Easy):** Attackers rotate fast-flux IPs, Tor exit nodes, or cheap VPS providers in minutes.
3. **Domain Names (Simple):** Domain Generation Algorithms (DGA) generate thousands of fallback domains daily.
4. **Network / Host Artifacts (Annoying):** Modifying user-agent strings, registry run-keys, or URI formats requires recompilation.
5. **Tools (Challenging):** Blocking Cobalt Strike, Mimikatz, or Metasploit forces attackers to write or buy custom tooling.
6. **TTPs – Tactics, Techniques, and Procedures (Tough / Maximum Pain):** Forcing an attacker to change *how* they operate (e.g., stopping Pass-the-Hash or DLL Hijacking) forces them to re-learn their tradecraft.

The MITRE ATT&CK Framework

What it is: A globally accessible knowledge base of adversary tactics and techniques based on real-world observations.

- **Tactics (The "Why"):** The attacker's objective (e.g., Initial Access, Execution, Persistence, Lateral Movement, Exfiltration).
- **Techniques (The "How"):** The specific method used (e.g., T1566 Phishing, T1078 Valid Accounts, T1059 Command and Scripting Interpreter).
- **Sub-Techniques:** Specific variants (e.g., T1566.001 Spearphishing Attachment).

3. Vulnerability Management (VM) & Risk Assessment

First Principles: The Vulnerability Lifecycle

Everyday Analogy: Think of hospital infection control. Doctors don't wait for sepsis to occur; they inspect surgical tools (Discovery), prioritize sterilization based on surgical urgency (Prioritization), disinfect tools or isolate infected rooms (Remediation), and take swab cultures to ensure zero bacteria remain (Verification).

Discovery (Nessus/Qualys scans) $\longrightarrow$ **Prioritization** (CVSS + EPSS) $\longrightarrow$ **Remediation** (Patch/Compensating Control) $\longrightarrow$ **Verification** (Rescan)

Scoring Vulnerabilities: CVSS vs. EPSS vs. CISA KEV

The Modern Vulnerability Triad

Interviewers frequently test if you know the difference between **Severity** and **Real-World Exploitability**:

- **CVSS v3.1 (Common Vulnerability Scoring System):** Measures theoretical severity (0.0 to 10.0). Based on Base Metrics: Attack Vector (AV: Network/Local), Attack Complexity (AC), Privileges Required (PR), User Interaction (UI), Scope (S), and Impact on Confidentiality, Integrity, Availability (C/I/A).
- **EPSS (Exploit Prediction Scoring System):** A dynamic machine-learning probability (0% to 100%) predicting whether a CVE will be exploited in the wild within the next 30 days.
- **CISA KEV (Known Exploited Vulnerabilities Catalog):** The definitive US federal list of CVEs actively weaponized by ransomware syndicates or nation-states. If a CVE is on KEV, remediation is mandatory immediately regardless of base CVSS score!

Cyber Risk Calculation Formula

$$\text{Cyber Risk} = \text{Threat (Actor capability \& intent)} \times \text{Vulnerability (Weakness)} \times \text{Asset Impact (Criticality of PHI/Data)}$$

If an internal server has a critical RCE vulnerability (CVSS 9.8) but is air-gapped with zero network access and contains no patient data, its risk score is low. Conversely, an API with a medium CVSS 5.3 flaw that exposes prescription fulfillment routes directly to the internet carries **critical operational risk**.

4. Security Operations Center (SOC) Metrics & Reporting

As stated in the JD, Evernorth requires interns to *"contribute to security metrics, dashboards, and reporting to enhance cybersecurity operations."*

Key SOC Metrics You Must Memorize

Metric	Formal Definition	Goal / Healthy Target	Analytic Value
MTTD (Mean Time to Detect)	Average elapsed time between an adversary's initial breach and security alert generation.	$<$ 15 minutes (automated alerts)	Identifies visibility gaps and sensor blind spots.
MTTA (Mean Time to Acknowledge)	Average time an analyst takes to claim a generated alert in the triage queue.	$<$ 5 minutes	Detects SOC staffing bottlenecks and triage queues.
MTTR (Mean Time to Respond / Remediate)	Time taken to contain, isolate, and eradicate an active threat once confirmed.	$<$ 30–60 minutes	Measures effectiveness of SOAR playbooks and incident teams.
Dwell Time	Total elapsed duration an intruder roams undetected inside the corporate perimeter.	Target: Zero days (Industry avg: 10–16 days)	Direct indicator of enterprise defense depth.
False Positive Rate	Percentage of alerts investigated that turn out to be benign activity.	Target: $<$ 20% (Often $>$ 75% in noisy rules)	Pinpoints SIEM rule debt causing analyst burnout.

How Anshika Explains Metrics Engineering in the Interview

Interview Answer: How would you contribute to security metrics and dashboards?

Anshika's Answer: "In my machine learning AML project, raw models generated thousands of transaction flags, which overwhelmed investigators. I designed feature dashboards that clustered flags by behavioral risk and cut false positives significantly.
At Evernorth, I would apply this exact analytical mindset to SOC operations. Using tools like Power BI, Splunk dashboards, or Python scripts, I would build automated ETL pipelines that aggregate telemetry from SIEM, EDR, and vulnerability scanners into three distinct dashboard views:

1. **Executive View:** High-level MTTR trends, percentage of critical CVEs patched within our 14-day SLA, and third-party vendor risk scores.
2. **Operational SOC View:** Live queue depth, alert-to-incident conversion ratio, and top 10 noisy detection rules causing alert fatigue.
3. **Threat Intelligence View:** MITRE ATT&CK heatmap coverage showing which techniques Evernorth has active detection rules for versus blind spots."

5. Incident Response (IR) Lifecycle (NIST SP 800-61 Rev. 2)

1. Preparation ⟶ 2. Detection & Analysis ⟶ 3. Containment, Eradication & Recovery ⟶ 4. Post-Incident Review

Step-by-Step Breakdown for Healthcare Context

1. **Preparation:** Hardening endpoints, configuring SIEM centralized log retention, deploying EDR agents (CrowdStrike/Defender), enforcing MFA, establishing out-of-band communication channels (Signal/Teams) in case primary email is compromised.
2. **Detection & Analysis:** Correlating anomalies across network proxies, authentication logs, and endpoint telemetry. Scoping the blast radius: which servers, patient databases, or service accounts are touched?
3. **Containment (Short-Term vs. Long-Term):**
   - *Short-Term:* Severing network interfaces via EDR host isolation (without powering off the machine, which destroys RAM volatility artifacts!), revoking compromised Kerberos/OAuth tokens, blocking attacker C2 domains at the DNS firewall.
   - *Long-Term:* Applying temporary ACL firewall blocks and creating memory snapshots for forensic triage.
4. **Eradication & Recovery:** Rebuilding compromised systems from known-clean golden images, rotating all domain administrative passwords, verifying database integrity against backups, and slowly restoring network traffic under enhanced monitoring.
5. **Post-Incident Activity (Lessons Learned):** Documenting root cause, calculating financial/PHI exposure, updating SIEM detection rules to prevent identical future exploitation, and briefing leadership.

6. High-Yield Cybersecurity Q&A for the Technical Interview

Q1: What is the difference between an Indicator of Compromise (IoC) and an Indicator of Attack (IoA)?

Answer:

- **IoC (Reactive / Forensic Evidence):** Evidence that an attack *has already occurred*. Examples include a known malware file hash (e.g., MD5/SHA-256), a malicious IP address communicating with command-and-control, or a specific malicious registry key. It tells you *what* happened.
- **IoA (Proactive / Behavioral Intent):** Evidence that an attack *is actively in progress*, regardless of the specific malware used. Examples include repeated LSASS memory access, suspicious PowerShell execution with base64 encoded bypass flags, or unauthorized privilege escalation. It tells you *why* and *how* an attacker is moving.

Q2: How does a Denial of Service (DoS) differ from a Distributed Denial of Service (DDoS), and how do you mitigate it?

Answer: A DoS attack originates from a single IP address or host, whereas a DDoS attack leverages thousands of geographically distributed bots (botnets) simultaneously overwhelming the target with traffic (SYN floods, UDP amplification, or HTTP GET floods).

- **Mitigation:** Cloud scrubbing centers (Cloudflare, AWS Shield, Azure DDoS Protection), rate-limiting API endpoints, deploying Web Application Firewalls (WAF) to inspect Layer 7 HTTP patterns, and configuring Anycast DNS to disperse traffic.

Q3: What is the difference between Symmetric and Asymmetric Encryption?

Answer:

- **Symmetric Encryption (e.g., AES-256):** Uses the *same secret key* for both encryption and decryption. It is computationally extremely fast and ideal for encrypting bulk data at rest (e.g., patient database drives, hard disks). Challenge: Secure key distribution.
- **Asymmetric Encryption (e.g., RSA-4096, ECC):** Uses a mathematically linked *key pair*: a Public Key (freely distributed for encryption) and a Private Key (kept strictly secret for decryption). It is computationally heavier and used for key exchange, digital signatures, and establishing TLS handshakes.

Q4: Explain Zero Trust Architecture in the context of Evernorth.

Answer: Traditional cybersecurity relied on the "Castle-and-Moat" model: once inside the VPN or corporate office network, you were implicitly trusted. **Zero Trust** operates on the core axiom: *"Never trust, always verify."*

- **Core Principles:**
  1. *Explicit Verification:* Always authenticate and authorize based on all available data points (user identity, device health, location, data classification).
  2. *Least Privilege Access:* Limit user access with Just-In-Time (JIT) and Just-Enough-Access (JEA) permissions.
  3. *Assume Breach:* Segment networks into micro-perimeters, encrypt all internal traffic, and analyze telemetry in real time.

Q5: A critical vulnerability is disclosed on Friday evening with CVSS 9.8. How do you decide whether to take down an Evernorth pharmacy fulfillment server to patch it?

Answer: "I would use a structured risk-triage framework rather than reacting on emotion:

1. **Assess Exposure & Compensating Controls:** Is the server directly exposed to the public internet, or is it isolated in an internal VPC behind a WAF? If a WAF rule can immediately inspect and block the attack payload, we apply the virtual patch immediately without restarting the host.
2. **Check EPSS & Active Exploitation:** Is there an active public exploit on GitHub or CISA KEV? If yes, the likelihood is extreme.
3. **Evaluate Patient Impact & Availability:** Taking down a pharmacy routing cluster during peak hours could prevent emergency medications from reaching patients. I would check if high-availability redundancy (active-passive failover) is available to patch servers sequentially with zero downtime. If downtime is mandatory, I coordinate an emergency off-peak maintenance window with clinical stakeholders."

Q6: What is the difference between EDR, SIEM, and SOAR?

Answer:

- **EDR (Endpoint Detection and Response):** Software agents running on workstations and servers (e.g., CrowdStrike Falcon, Microsoft Defender for Endpoint) that record kernel-level events, process creation, network sockets, and can isolate the host.
- **SIEM (Security Information and Event Management):** Centralized data engine (e.g., Splunk, Microsoft Sentinel) that ingests logs from hundreds of sources (firewalls, Active Directory, cloud audit logs, EDR), normalizes them, and correlates patterns across systems.
- **SOAR (Security Orchestration, Automation, and Response):** The execution engine that connects tools and automates repetitive tasks via playbooks (e.g., automatically isolating an infected machine, querying VirusTotal, and disabling an Active Directory user account when an alert fires).